

UNIVERSIDAD MAYOR DE SAN ANDRÉS

Carrera de Informática – Seguridad de la Información



Proyecto: Evaluación de seguridad de Módulos de Autenticación Web - Escudo Pet Spa

Nombre del informe: Informe de Pentesting – Evaluación de seguridad y funcionalidad de módulos de autenticación en entorno local

Materia: Taller Técnico Superior

Analista de seguridad: Limachi Tapia Guillermo

Estudiante revisado: Cantuta Quispe Elvis Alberth

Fecha: 18/05/26

Clasificación del documento: Académico / Confidencial

Análisis hipotético y planificación ofensiva

1. RESUMEN EJECUTIVO

El presente informe documenta el análisis de superficie de ataque, identificación teórica de vulnerabilidades y simulación de vectores de ataque sobre el sistema "Pet Spa", considerando los módulos correspondientes a Administrador, Recepción, Groomer y Cliente.

Debido a limitaciones del entorno, las evaluaciones fueron realizadas mediante análisis audiovisual del sistema y revisión conceptual de seguridad ofensiva.

2. OBJETIVOS

2.1 Objetivo General

Ejemplo:

Evaluar teóricamente la seguridad del sistema Pet Spa mediante técnicas de reconocimiento, análisis de autenticación, revisión de controles RBAC (Control de Acceso Basado en Roles) y simulación de pruebas de intrusión.

2.2 Objetivos Específicos

- Analizar el sistema de autenticación.
- Evaluar posibles debilidades JWT (JSON Web Token).
- Identificar riesgos de escalación de privilegios.
- Evaluar políticas de contraseñas.
- Detectar malas prácticas visibles.
- Proponer medidas de mitigación.

3. ALCANCE

Aquí defines qué módulos se analizaron.

Ejemplo:

Módulos Evaluados

- Login
- Registro de clientes
- Panel Administrador
- Recepción
- Groomer
- Cliente
- Gestión de usuarios

- Reportes
- Reservas
- Historiales

LIMITACIONES DEL ENTORNO

El análisis realizado corresponde a una evaluación teórica basada en material audiovisual proporcionado por terceros. No se contó con acceso directo al entorno funcional, servidor, base de datos, APIs ni tráfico real de red, por lo que no fue posible ejecutar explotación activa ni validaciones prácticas de vulnerabilidades.

4. METODOLOGÍA

Metodología Utilizada

- Reconocimiento pasivo
- Análisis visual de autenticación
- Evaluación OWASP Top 10
- Simulación de vectores de ataque
- Evaluación RBAC
- Análisis de malas prácticas

5. RECONOCIMIENTO Y SUPERFICIE DE ATAQUE

Hallazgo	Observación	Superficie de ataque	Vulnerabilidad teórica	Pruebas hipotéticas	Simulación de ataque	Riesgo	Impacto	Severidad	Mitigación	Mejora recomendada
Implementación de hashing potencialmente débil en XAMPP/PHP	El sistema utiliza hashing de contraseñas en PHP/XAMPP, pero no se evidencia el uso de algoritmos robustos modernos.	Base de datos, autenticación	Vulnerabilidad a cracking offline y rainbow tables	Fuerza bruta offline, rainbow tables, cracking de hashes	Ante filtración de la BD, un atacante podría revertir contraseñas usando GPUs o tablas precalculadas.	Compromiso masivo de credenciales	Crítico	Crítica	Uso de bcrypt/Argon2id y salts aleatorios	Migrar completamente a Argon2id
Ausencia de recuperación de contraseña	El sistema no cuenta con módulo de recuperación de contraseña.	Gestión de cuentas y autenticación	Dependencia de prácticas inseguras para restablecimiento	Ingeniería social, recuperación manual insegura	Usuarios podrían compartir credenciales o reutilizar contraseñas débiles.	Exposición de credenciales y malas prácticas	Medio	Media	Recuperación segura mediante tokens temporales	Implementar recuperación con validación multifactor
Ausencia de CAPTCHA y MFA en autenticación	El login permite acceso directo sin CAPTCHA ni MFA.	Login y sesiones	Fuerza bruta y credential stuffing	Bots automatizados, rotación IP, phishing	Un atacante podría automatizar accesos hasta comprometer cuentas válidas.	Acceso no autorizado y robo de cuentas	Alto	Alta	CAPTCHA adaptativo, MFA y rate limiting	Implementar MFA obligatorio y protección dinámica
Formularios administrativos sin validaciones estrictas	Los formularios permiten ingresar cualquier información arbitraria.	Panel administrativo y formularios internos	Corrupción de datos y almacenamiento de payloads maliciosos	XSS, inputs inválidos, inserción masiva	Un atacante podría almacenar datos maliciosos afectando integridad del sistema.	Corrupción de datos y XSS persistente	Alto	Alta	Sanitización y validación backend	Aplicar esquemas tipados y validaciones centralizadas
Políticas débiles de validación de contraseñas	Solo existen alertas básicas del navegador y no validaciones robustas del sistema.	Registro y gestión de credenciales	Uso de contraseñas débiles	Contraseñas comunes, fuerza bruta	Usuarios podrían registrar passwords fáciles de comprometer.	Compromiso de cuentas	Alto	Alta	Validación robusta y blacklist de passwords	Implementar políticas avanzadas de contraseñas
Registro masivo de clientes sin controles anti automatización	El registro público no posee CAPTCHA y permite llenar datos arbitrarios.	Registro público, formularios, BD	Automatización masiva de registros	Bots, flood de registros, correos temporales	Un atacante podría llenar la BD con cuentas falsas y degradar el sistema.	Saturación de BD y degradación del servicio	Alto	Alta	CAPTCHA y validación previa	Implementar controles anti automatización
Sistema de auditoría limitado y sin SIEM	La auditoría depende de logs internos de Laravel almacenados en storage.	Logs, auditoría y storage	Monitoreo insuficiente y posible manipulación de evidencias	Alteración de logs, eliminación de registros	Un atacante con acceso al servidor podría modificar o eliminar evidencias.	Pérdida de trazabilidad y monitoreo	Alto	Alta	SIEM y logs inmutables	Integrar SIEM y almacenamiento externo seguro

6. RECOMENDACIONES GENERALES Y CONCLUSIONES ESPECIFICADA POR CASOS

Hallazgo 1 — Implementación de hashing potencialmente débil en entorno XAMPP/PHP

Observación

El sistema fue desarrollado en PHP puro sobre XAMPP y utiliza hashing de contraseñas, pero no se evidencia el uso de algoritmos robustos modernos equivalentes a implementaciones endurecidas como bcrypt/Argon2 correctamente configuradas.

Superficie de ataque

- Base de datos
- Sistema de autenticación
- Gestión de contraseñas

Vulnerabilidad teórica

Posible vulnerabilidad a ataques de cracking offline mediante diccionarios, rainbow tables o fuerza bruta acelerada.

Pruebas hipotéticas

- Ataques rainbow table
- Cracking de hashes
- Evaluación del algoritmo hash
- Fuerza bruta offline

Simulación de ataque

Ante una filtración de la base de datos, un atacante podría intentar revertir contraseñas utilizando tablas precalculadas o GPUs especializadas.

Riesgo

- Compromiso masivo de credenciales
- Acceso no autorizado
- Reutilización de contraseñas

Impacto: Crítico

Severidad: Crítico

Mitigación

- Uso de bcrypt o Argon2id
- Salt aleatorio por contraseña

- Incremento de costo computacional

Mejora recomendada

Migrar completamente a Argon2id con configuración robusta y políticas modernas de hashing.

Hallazgo 2 — Ausencia de recuperación de contraseña

Observación

El sistema no implementa módulo de recuperación de contraseña.

Superficie de ataque

- Gestión de cuentas
- Sistema de autenticación

Vulnerabilidad teórica

Dependencia total del administrador o prácticas inseguras para restablecimiento manual de credenciales.

Pruebas hipotéticas

- Recuperación manual insegura
- Reutilización de contraseñas
- Compartición insegura de credenciales

Simulación de ataque

Usuarios podrían reutilizar contraseñas inseguras o depender de mecanismos no controlados para recuperar acceso.

Riesgo

- Malas prácticas operativas
- Exposición de credenciales
- Ingeniería social

Impacto: Medio

Severidad: Medio

Mitigación

- Implementar recuperación segura
- Tokens temporales
- Verificación de identidad

Mejora recomendada

Agregar módulo seguro de recuperación con expiración y validación multifactor.

Hallazgo 3 — Ausencia de CAPTCHA y MFA en autenticación

Observación

El login permite acceso directo mediante correo y contraseña sin CAPTCHA ni autenticación multifactor.

Superficie de ataque

- Login
- Gestión de sesiones
- Autenticación

Vulnerabilidad teórica

Exposición elevada a ataques automatizados y compromiso de cuentas.

Pruebas hipotéticas

- Fuerza bruta
- Credential stuffing
- Automatización de login
- Rotación de IPs

Simulación de ataque

Un atacante podría automatizar intentos de autenticación utilizando credenciales filtradas hasta comprometer cuentas válidas.

Riesgo

- Acceso no autorizado
- Robo de cuentas
- Compromiso de información

Impacto: Alto

Severidad: Alto

Mitigación

- CAPTCHA adaptativo
- MFA
- Rate limiting

Mejora recomendada

Implementar MFA obligatorio y protección dinámica frente a automatización.

Hallazgo 4 — Formularios administrativos sin validaciones estrictas

Observación

Los formularios de creación de empleados permiten ingresar cualquier tipo de información sin validaciones visibles.

Superficie de ataque

- Panel administrativo
- Formularios internos
- Gestión de empleados

Vulnerabilidad teórica

Posible corrupción de datos, almacenamiento de payloads maliciosos o inconsistencias lógicas.

Pruebas hipotéticas

- XSS almacenado
- Inputs inválidos
- Inserción masiva de datos
- Caracteres especiales

Simulación de ataque

Un atacante podría introducir datos maliciosos o excesivos afectando estabilidad e integridad del sistema.

Riesgo

- Corrupción de datos
- Saturación de BD
- XSS persistente

Impacto: Alto

Severidad: Alto

Mitigación

- Sanitización de entradas
- Validaciones backend
- Restricciones de formato

Mejora recomendada

Implementar validaciones centralizadas y esquemas tipados.

Hallazgo 5 — Políticas débiles de validación de contraseñas

Observación

No existen módulos robustos de validación de contraseñas; únicamente se observan alertas básicas del navegador.

Superficie de ataque

- Registro de usuarios
- Gestión de credenciales

Vulnerabilidad teórica

Contraseñas débiles o fácilmente predecibles podrían ser aceptadas.

Pruebas hipotéticas

- Uso de contraseñas comunes
- Fuerza bruta
- Credential stuffing

Simulación de ataque

Usuarios podrían registrar contraseñas débiles facilitando ataques automatizados posteriores.

Riesgo

- Compromiso de cuentas
- Acceso no autorizado

Impacto: Alto

Severidad: Alto

Mitigación

- Validación robusta de contraseñas
- Requisitos mínimos obligatorios
- Blacklist de contraseñas comunes

Mejora recomendada

Implementar validación interna robusta y políticas avanzadas de contraseñas.

Hallazgo 6 — Registro masivo de clientes sin controles anti automatización

Observación

El registro de clientes puede realizarse desde el login principal sin CAPTCHA y permitiendo llenado arbitrario de datos.

Superficie de ataque

- Registro público
- Base de datos
- Formularios

Vulnerabilidad teórica

Posible automatización masiva de registros y contaminación de la base de datos.

Pruebas hipotéticas

- Bots automatizados
- Flood de registros
- Uso de correos temporales

Simulación de ataque

Un atacante podría generar miles de cuentas falsas incluso sin validar correos, saturando recursos del sistema.

Riesgo

- Saturación de BD
- Degradación de rendimiento
- Contaminación de registros

Impacto: Alto

Severidad: Alto

Mitigación

- CAPTCHA
- Rate limiting
- Validación previa antes de persistencia

Mejora recomendada

Implementar controles anti automatización y limpieza automática de cuentas no verificadas.

Hallazgo 7 — Sistema de auditoría limitado y sin SIEM

Observación

La auditoría depende únicamente de logs internos generados por Laravel en el storage, sin panel administrativo dedicado ni integración SIEM.

Superficie de ataque

- Logs
- Auditoría
- Sistema de archivos

Vulnerabilidad teórica

Capacidad limitada de monitoreo centralizado y detección temprana de incidentes.

Pruebas hipotéticas

- Alteración de logs
- Eliminación de registros
- Accesos indebidos al storage

Simulación de ataque

Un atacante con acceso al servidor podría modificar o eliminar evidencias sin mecanismos avanzados de integridad.

Riesgo

- Pérdida de trazabilidad
- Respuesta tardía a incidentes
- Encubrimiento de actividad maliciosa

Impacto: Alto

Severidad: Alto

Mitigación

- SIEM
- Logs inmutables
- Centralización de auditoría

Mejora recomendada

Integrar SIEM y almacenamiento externo seguro de logs críticos.

